Vincent Lam

IAM & Security Engineering | AI Agents & LLM Security | Open to remote

Sacramento, CA | v812.io@gmail.com | xeoul.github.io | github.com/Xeoul | linkedin.com/in/vincentlam812

Identity and security engineer (B.S. Computer Science, 2025) who makes least privilege something the system enforces, not a policy document: zero-standing-privilege access, policy-as-code, and LLM features that hold up against prompt injection. Takes projects end to end (threat model, code, CI gates, live demo) and brings 2+ years of compliance- and accuracy-critical work for the State of California.

SKILLS

Identity & access: Least privilege, ABAC/RBAC, Cedar policy-as-code, SCIM 2.0, access reviews, OIDC/JWT, MFA, AWS IAM & STS
AI & agents: Claude API, tool use, structured outputs, prompt injection defense, agent permissioning, Pydantic / Zod
Security: STRIDE threat modeling, NIST 800-53 / SOC 2 mapping, audit logging, detection rules, SIEM (OCSF), CodeQL, Bandit
Languages & tools: Python, TypeScript, JavaScript, SQL, Java, R, FastAPI, Next.js, React, Docker, GitHub Actions, Power Automate

PROJECTS (2026)

Aegis – Just-in-time access platform, zero standing privilege | Python, FastAPI, Cedar, OIDC, SCIM, AWS STS — Live demo | Code

- **Removed standing access.** Cedar policies decide each request on real user and resource attributes; restricted access needs MFA step-up and a second approver; approved grants become scoped AWS STS credentials that expire on their own (2–72 hours by sensitivity, 1-hour break-glass) and are revoked on SCIM 2.0 joiner/mover/leaver events.
- **Made an LLM safe to put in front of access decisions.** Claude only extracts fields from untrusted text, injection detection sends manipulated requests to a human, and tests with a fully hijacked parser check that policy still decides.
- **Made every decision auditable.** HMAC-chained audit log with signed checkpoints that catch truncation, recertification campaigns, 6 detection rules with OCSF SIEM export, a STRIDE threat model and a NIST 800-53 / SOC 2 / ISO 27001 control map.
- **Shipped it like production code.** 186 tests at 93% coverage gated in CI by CodeQL, Bandit, mypy and pip-audit, OIDC sign-in verified against Keycloak, and a live demo that runs the real Cedar engine in the browser.

Kumo – Claude Code agent on a home NAS, driven from Telegram | Docker, Bash, Claude Code — Write-up

- **Treated the agent as a privileged identity.** Listed the threats first (strangers messaging it, injected instructions, reaching the home network, leaked secrets), then bounded it: one allow-listed user, no root, nothing mounted from the NAS, no open ports, destructive commands gated behind one-tap approvals, and a hook that mirrors every command to my phone.

Privacy Blocker – Local-first data-broker opt-out tool | JavaScript, Web Crypto, GitHub Actions — Live demo | Code

- **Built so it cannot leak what it protects.** Personal data is encrypted in the browser (PBKDF2-SHA256, 600k iterations, then AES-256-GCM) with a 10-minute idle lock, and a CSP of connect-src 'none' blocks all outbound requests.
- **Turned a manual chore into a scheduled job.** Sends CCPA deletion requests to ~25 brokers per run on a schedule, logging no personal data.

Installous – AI stock research agent | TypeScript, Next.js, Claude API — Live demo | Code

- **Grounded the AI advisor in live data.** A tool-using Claude advisor gets quotes, fundamentals and news through Zod-validated tools and shares a per-datatype cache (1–60 min) with the app, so follow-up questions never refetch.
- **Tested the scoring model in the open.** A rules-only $100k paper fund trades its five-factor score of ~50 large caps every 30 minutes via GitHub Actions and logs every trade's reason to a public history benchmarked against SPY, backed by a 5-year backtest.

W.E.M.U 2.0 – Senior project, team of 8, for the CA Dept. of Consumer Affairs | Node.js, Selenium

- **Moved licensing forms to a new system at scale.** Co-built the form-migration system for 3.4M licenses across 36 entities; wrote the back-end logic for the site's button actions; owned the production stage, contact forms page and Selenium role-based access tests.

EXPERIENCE

Office of Legislative Counsel – *Office Technician (Typing)* — *Sep 2026 – Present*

- Produce and publish legislation in document-workflow systems on a 5-person team, delivering finals through secure channels.

California Department of Health Care Services

Student Assistant – Public Hospital Redirection Payments & Veterans Homes Programs — *Jan 2025 – Jun 2025*

- **Caught and resolved discrepancies before payment release.** Reconciled thousands of claims and financial reports per cycle from hospitals, doctors and other providers statewide for state and federal reimbursement programs, with fiscal and policy stakeholders.

Student Assistant – SharePoint Program & Records Support — *Nov 2022 – Apr 2024*

- **Replaced manual document sends.** Helped build a Power Automate flow for the monthly, quarterly and annual sends; handed it off.
- **Gave staff one place to find liaisons.** Built the landing page on the Outlook Global Address List, with access limited to designated staff.
- **Kept SharePoint healthy.** Resolved access issues, broken links and version conflicts; QA'd accuracy, metadata and accessibility.

California Housing Finance Agency – *Student Assistant, Loan Operations & Data Quality* — *May 2022 – Oct 2022*

- **Sped up loan-data review** by adding features to 3+ existing Python and R data-validation scripts.

EDUCATION

California State University, Sacramento – B.S. Computer Science — Aug 2025
Coursework: Computer System Attacks & Countermeasures, Computer Networks, Operating Systems, Databases, Data Mining